

Literature Review

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

12. Secondary Research

All statements in this section are [SECONDARY] and cite the numbered references in Section 42. Where the team draws an inference from a source rather than repeating it, the inference is marked "(inference)".

12.1 Authentication and Authorization

Definitions. NIST SP 800-63-4 [1] defines authentication as the process of verifying that a claimant controls an authenticator bound to a subscriber's identity, and treats authorization (what the authenticated subscriber may do) as a separate function performed by the relying party after authentication. The same separation appears in classic protection-system design: Saltzer and Schroeder [14] describe authentication as establishing the principal and access control as deciding, per request, whether that principal may perform an action.

Authenticator types and assurance. SP 800-63B-4 [1] classifies authenticators by factor (something you know, have, are) and by whether they are single-factor or multi-factor, and defines Authentication Assurance Levels. Relevant to this project: a possession-based authenticator (a card or phone credential) provides single-factor authentication unless it is protected by a second factor (a PIN or biometric unlocking the phone). A "hardware cryptographic authenticator" that performs challenge–response is rated more highly than an authenticator that merely emits a static secret, because a static secret can be captured and replayed [1].

Facility access specifically. NIST SP 800-116 Rev 1 [2] applies these ideas to physical access control for the US federal PIV card. Its key contributions for our design: (a) it distinguishes reading a card identifier (weak, cloneable) from cryptographic challenge–response with the card (strong); (b) it recommends the authentication mechanism be chosen per area according to risk, with higher-risk areas requiring stronger mechanisms; and (c) it insists the physical access control system check the credential's current revocation status, not just its expiry date. Implication (inference): a campus perimeter is a moderate-risk area where a cryptographic possession factor plus a human photo check is proportionate; interior high-risk areas would need more.

Comparative evaluation of schemes. Bonneau et al. [33] evaluate authentication schemes on 25 usability, deployability and security properties and show that no scheme dominates; every choice trades some property for another. We adopt the same posture in Section 13: the technology comparison reports trade-offs, not a winner.

12.2 QR-code authentication

QR codes are a two-dimensional optical symbology standardised in ISO/IEC 18004 [25]. They encode data; they do not perform computation. Security therefore depends entirely on the data encoded and how the reader validates it.

Krombholz et al. [21] survey QR-code attacks and note that (a) a QR code is trivially copied by photographing it, (b) users cannot read the content and therefore cannot detect substitution, and (c) attackers can overlay malicious codes on legitimate ones. For an access credential this means a static QR code (one that never changes) is equivalent to a printed password: anyone who photographs it can replay it indefinitely.

The standard mitigation (inference from [1], [37], [40]) is to make the code dynamic and signed: the phone generates a fresh code every 30–60 seconds containing a credential identifier, a timestamp or counter, and a digital signature or MAC computed with a key held in the phone's secure storage. The reader verifies the signature, checks the timestamp window, and rejects any code it has already seen. This converts QR from "static secret" to "short-lived signed assertion", which resists replay after the window closes but still cannot resist a real-time relay (an attacker who screenshots and forwards the code within the window). RFC 6238 TOTP [37] is the standard model for time-based codes; RFC 7519 JWT [40] and RFC 8032 EdDSA [38] provide standard formats and signature schemes.

Usability properties (inference from [21], [12]): QR requires the user to unlock a phone, open an app, and orient the screen to a camera; this is slower and more failure-prone (glare, cracked screens, dead battery) than a tap, but it requires no special phone hardware and works on any smartphone with a screen.

12.3 RFID authentication

"RFID" covers several incompatible technologies. The distinction matters more than the label.

Low-frequency (125 kHz) proximity cards (e.g., HID Prox, EM4100 family) transmit a fixed identifier when powered by the reader field. They have no cryptography. Cloning requires only a low-cost reader/writer; the identifier is the credential. Anderson [31] and Verdult [32] treat this class as providing identification, not authentication.

High-frequency (13.56 MHz, ISO/IEC 14443) cards [23] range from memory cards to smart cards. The most-deployed memory card, MIFARE Classic, uses the proprietary CRYPTO1 cipher, which was reverse-engineered and broken in 2008 by two independent groups [4, 5]; keys can be recovered and cards cloned in seconds with commodity hardware. HID's iCLASS legacy product was similarly broken in 2012 [6]. Even a card with a sound cipher can leak keys through side channels if the hardware is not protected: Oswald and Paar recovered the 3DES key from MIFARE DESFire MF3ICD40 by power analysis [7]. Modern products (MIFARE DESFire EV2/EV3, MIFARE Plus EV2) implement AES-128 mutual authentication with standard primitives and are certified under Common Criteria [41]; we cite the data sheets only for the primitives used, not as proof of security.

Lessons for design (inference): the card must perform a cryptographic challenge–response with a per-card key; the reader must never accept a bare UID; and the design must assume some deployed cards will eventually be broken, so revocation and key rotation must be operationally cheap (Section 26).

Relay attacks. Any contactless protocol that does not measure distance is vulnerable to relay: the attacker holds one device near the victim's card and another near the reader and forwards messages. Hancke and Kuhn [18] proposed distance-bounding protocols as a countermeasure; Francillon et al. [19] demonstrated practical relays against car keyless-entry systems; Francis et al. [20] demonstrated relays using two NFC phones. Commercial access-control cards do not implement distance bounding. The practical mitigation in a staffed gate is the human: the guard sees whether the person tapped a card. Relay is therefore a residual risk, addressed by the photo check and by anomaly detection rather than by cryptography (Section 24).

12.4 NFC authentication

NFC (ISO/IEC 18092 [24]) is a superset of ISO/IEC 14443 [23] that lets a phone act as a reader, as a card (card emulation), or peer-to-peer. For access control the relevant mode is card emulation: the phone presents a credential to a reader exactly as a smart card would.

The security advantage of a phone over a card (inference from [1]) is that the phone can require a second factor before releasing the credential: the phone must be unlocked (PIN or biometric), so a stolen phone is not a usable credential until the thief also has the unlock secret. Keys can be stored in hardware-backed storage (Secure Element or Trusted Execution Environment). The disadvantages are dependence on battery, OS, and platform policy; not all phones expose card emulation to third-party apps; and a subset of students will not have a compatible phone (A3, [DATA REQUIRED]).

Existing deployments: Apple states that since 2018 students at several US universities can hold their student ID in Apple Wallet and use it for building access, with campus card systems provided by partners [35]. We cite this only as evidence that phone-based NFC campus credentials are a deployed pattern; Apple's press releases make no verifiable security claims and we make none on their behalf.

NFC shares the relay-attack exposure of any contactless protocol [20].

12.5 Existing campus systems

Reliable public documentation of specific Indian university gate systems is sparse; we do not claim any Indian institution uses any particular technology. What can be said from published sources:

- Card-based campus systems in North America and Europe typically combine a photo ID with a 13.56 MHz contactless chip used for doors, libraries, meals and printing; the same card serves many purposes (inference from the multi-application design of ISO/IEC 14443 products [41] and the Apple/Blackboard announcements [35]).
- Mobile credentials via Apple Wallet and Google Wallet are offered at named US universities [35].
- The hotel-lock breaches below are the best-documented evidence of what goes wrong in large contactless-credential deployments and are directly transferable to campus cards using the same chip families.

12.6 Hotel and physical access-control systems

Three widely reported cases:

Case	Year	Technology	Root cause	Lesson
Onity HT locks [36]	2012	Battery-powered lock with DC port	Programming port exposed the lock's memory and key without authentication; a hand-built device opened the lock	Physical ports and debug interfaces on readers are attack surfaces; readers must be treated as potentially compromised (SEC-18)
Vision by VingCard (Assa Abloy) [8]	2018	RFID (MIFARE Classic-based) keycards	Predictable key-derivation let researchers compute a property-wide master key from any single discarded card, even an expired one	Expired credentials still leak secrets; the credential system must not derive site keys from data readable on cards; retirement must include key rotation (Section 26)
Unsaflok, dormakaba Saflok [9]	2024	MIFARE Classic keycards, System 6000	Weak key derivation and card encryption; one read card allowed forging a pair of cards that open any door on the property	The same MIFARE Classic weakness known since 2008 [4, 5] remained in millions of doors 16 years later; migration is slow, so revocation and monitoring must compensate

Common to all three: the systems authenticated the card (does it hold the right bytes?) rather than authenticating the holder, and none had a revocation check that could stop a forged card. This is the failure pattern our authentication/authorization separation is meant to prevent.

12.7 Usable security and human factors

- Users are not the enemy. Adams and Sasse [10] showed that users bypass security mechanisms when those mechanisms conflict with their tasks and when they do not understand the rationale; blaming users is unproductive. For our gate this predicts that guards will wave people through when the check is slow, and students will share credentials when replacement is slow.
- Rational rejection. Herley [11] argues that users reject security advice when its cost to them exceeds the benefit they receive; the cost of security is borne by many users constantly while the benefit accrues to the institution rarely. Design consequence: the authenticated path must cost the student less effort than today, not more.
- Compliance budget. Beaument, Sasse and Wonham [17] show that people have a finite budget of effort for security compliance; spending it on low-value checks leaves none for high-value ones. Design consequence: add friction (a second factor, a manual check) only when risk indicators justify it.
- Why Johnny can't encrypt. Whitten and Tygar [12] demonstrated that security software fails when its interface does not match users' mental models and when errors are silent or cryptic. Design consequence: the guard's screen must show the decision and the reason, in plain language, not a status code.
- Secure interaction design. Yee [13] proposes principles including path of least resistance (the easiest path should be the secure one), visibility (the user should see the security-relevant state), revocability, expected ability, and clarity. These are adopted as design principles in Section 33.
- Human in the loop. Cranor [16] models the human as a component that receives a communication, attends to it, comprehends it, and acts; failures occur at each stage. For the gate, the guard is the human in the loop; the screen is the communication; comprehension must be near-instant.
- Heuristic evaluation. Nielsen's ten heuristics [15] remain the standard checklist for expert evaluation of interfaces and are used in Section 36 alongside the usable-security principles above.
- Historical overview. Garfinkel and Lipford [34] and Sasse et al. [42] synthesise these themes and argue that security and usability are complementary when designed together, not opposing goals to be traded.

12.8 Privacy and data minimisation

- Legal frame. India's Digital Personal Data Protection Act, 2023 [22] requires that personal data be processed only for a lawful purpose, with consent or under specified legitimate uses; obliges data fiduciaries to implement reasonable safeguards, to erase personal data when the purpose is served, and to give data principals the right to access a summary of their personal data being processed. An institution operating an entry-log system would be a data fiduciary; students and visitors would be data principals.
- Privacy framework. ISO/IEC 29100 [26] enumerates privacy principles including consent and choice, purpose legitimacy and specification, collection limitation, data minimisation, use/retention/disclosure limitation, accuracy, openness/transparency, individual participation and access, and accountability.
- Privacy by Design. Cavoukian [27] frames privacy as proactive, default, embedded in design, full-functionality (positive-sum), end-to-end secure, visible/transparent, and user-centric. The "positive-sum" claim is directly relevant: the guard's screen can show less personal data and still support a better decision than today's card.

- Design consequences (inference): the gate decision needs a photo, a display name, a role and a decision; it does not need roll number, phone, address or hostel. Logs need a pseudonymous credential identifier, gate, time and decision; re-identification should require a separate, audited administrative action. Retention should be fixed and short.

12.9 Security threats and engineering principles

- Design principles. Saltzer and Schroeder's principles [14] (economy of mechanism, fail-safe defaults, complete mediation, open design, separation of privilege, least privilege, least common mechanism, psychological acceptability) are adopted as security design principles in Section 33. "Open design" is the source of requirement SEC-20 (no security through obscurity). "Complete mediation" is the source of checking revocation on every access, not just at issuance.
- Threat modelling method. Shostack [30] describes STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) applied per data-flow-diagram element and per trust boundary. Section 24 applies STRIDE to the DFD in Section 29.
- Application-layer controls. OWASP ASVS [29] provides verifiable requirements for authentication, session management, access control, cryptography-at-rest, and logging that Phase 2 will use as an implementation checklist; the OWASP Logging Cheat Sheet [29] specifies what must and must not be logged (never secrets, tokens or full credentials).
- Key management. NIST SP 800-57 [3] covers key generation, storage, rotation, and destruction; applied to per-card keys, signing keys, and the offline revocation-list signing key in Section 27.
- Transport security. TLS 1.3 [39] with mutual authentication (client certificates on readers) is the standard for reader-to-server communication.

15. Research Gap

The published literature and deployed systems reviewed above cover each concern in isolation:

- Cryptographic strength of contactless credentials is well studied [4–7, 41].
- Relay attacks are well characterised, with countermeasures that are not commercially deployed [18–20].
- Facility-access guidance exists for high-assurance government settings with dedicated budgets and mandatory PIV cards [2].
- Usable-security principles are well established but are mostly studied for end-user software such as e-mail, passwords and browsers [10–13, 17, 33].
- Privacy frameworks and law define principles but not how to apply them to a movement log at a gate [22, 26, 27].

What the review did not find is published design work that treats the following together, as one problem:

1. Two humans in the loop with different needs. The credential holder (student) and the operator (guard) both have usability constraints; the guard's interface is a security control in its own right, not just a display. Most usable-security work studies one user.
2. Authorization as a first-class, separately-communicated decision. Deployed systems collapse "card valid" and "entry allowed" into one signal (door opens). Our review found no design guidance on how to communicate the distinction to a non-technical operator so that a revoked student and a forged card produce different, actionable responses.
3. Fail-secure degradation under infrastructure failure in a low-resource setting. SP 800-116 assumes government-grade infrastructure. The question of how a campus gate should behave during a network or power outage without either opening the gate or stranding hundreds of students is not addressed in the sources reviewed.
4. Privacy-preserving audit of a movement log. The trade-off between an audit trail useful for incident response and a dataset that reveals every student's daily pattern is noted in the privacy literature in general terms but not resolved for access control specifically.
5. Campus-specific constraints: mixed device ownership, contract security staff with varying training, high peak loads at predictable times, and a population that is technically sophisticated and privacy-aware.

Gap statement. Existing access-control research and practice secure the credential but treat the operator, the authorization decision, failure behaviour and privacy as afterthoughts. This project studies the combined design problem of authentication, authorization, guard usability, fail-secure degradation, and privacy-preserving audit in a campus setting, and derives requirements for it from primary research with both students and security staff. The contribution of Phase 1 is a traceable requirements and design baseline for that combined problem; the contribution of Phase 2 will be an implementation that can be tested against it.

This gap statement is supported by the absence of matching results in the sources reviewed; it is not a claim that no such work exists anywhere. A broader systematic search is listed as a limitation in Section 39.

42. References

Numbering is fixed; all in-text citations use these numbers.

Standards and government sources

- [1] NIST. SP 800-63-4: Digital Identity Guidelines (with 800-63A-4 Identity Proofing, 800-63B-4 Authentication and Authenticator Management, 800-63C-4 Federation). National Institute of Standards and Technology, July 2025. <https://csrc.nist.gov/pubs/sp/800/63/4/final>
- [2] NIST. SP 800-116 Rev. 1: Guidelines for the Use of PIV Credentials in Facility Access. National Institute of Standards and Technology, June 2018. <https://csrc.nist.gov/pubs/sp/800/116/r1/final>
- [3] NIST. SP 800-57 Part 1 Rev. 5: Recommendation for Key Management. National Institute of Standards and Technology, May 2020.
- [4] F. D. Garcia, G. de Koning Gans, R. Muijters, P. van Rossum, R. Verdult, R. Wichers Schreur, B. Jacobs. "Dismantling MIFARE Classic." ESORICS 2008, LNCS 5283, Springer, pp. 97–114.
- [5] K. Nohl, D. Evans, Starbug, H. Plötz. "Reverse-Engineering a Cryptographic RFID Tag." USENIX Security Symposium 2008, pp. 185–193.
- [6] F. D. Garcia, G. de Koning Gans, R. Verdult, M. Meriac. "Dismantling iClass and iClass Elite." ESORICS 2012, LNCS 7459, Springer, pp. 697–715.
- [7] D. Oswald, C. Paar. "Breaking Mifare DESFire MF3ICD40: Power Analysis and Templates in the Real World." CHES 2011, LNCS 6917, Springer, pp. 207–222.
- [8] T. Tuominen, T. Hirvonen. "Ghost in the Locks" (Vision by VingCard vulnerability disclosure). F-Secure, April 2018. Reported in: A. Greenberg, "A One-Minute Attack Let Hackers Spoof Hotel Master Keys," Wired, 25 Apr 2018.
- [9] L. Wouters, I. Carroll, et al. "Unsaflok: Security vulnerabilities in dormakaba Saflok hotel locks." Disclosure site, March 2024. <https://unsaflok.com/>. Reported in Ars Technica, 21 Mar 2024.
- [10] A. Adams, M. A. Sasse. "Users Are Not the Enemy." Communications of the ACM 42(12), 1999, pp. 40–46.
- [11] C. Herley. "So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users." NSPW 2009, ACM, pp. 133–144.
- [12] A. Whitten, J. D. Tygar. "Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0." USENIX Security Symposium 1999.
- [13] K.-P. Yee. "User Interaction Design for Secure Systems." ICICS 2002, LNCS 2513, Springer, pp. 278–290.
- [14] J. H. Saltzer, M. D. Schroeder. "The Protection of Information in Computer Systems." Proceedings of the IEEE 63(9), 1975, pp. 1278–1308.
- [15] J. Nielsen. "Enhancing the Explanatory Power of Usability Heuristics." CHI 1994, ACM, pp. 152–158. Updated as "10 Usability Heuristics for User Interface Design," Nielsen Norman Group.
- [16] L. F. Cranor. "A Framework for Reasoning About the Human in the Loop." UPSEC 2008, USENIX.
- [17] A. Beutement, M. A. Sasse, M. Wonham. "The Compliance Budget: Managing Security Behaviour in Organisations." NSPW 2008, ACM, pp. 47–58.
- [18] G. P. Hancke, M. G. Kuhn. "An RFID Distance Bounding Protocol." SecureComm 2005, IEEE, pp. 67–73.
- [19] A. Francillon, B. Danev, S. Capkun. "Relay Attacks on Passive Keyless Entry and Start Systems in Modern Cars." NDSS 2011, Internet Society.
- [20] L. Francis, G. Hancke, K. Mayes, K. Markantonakis. "Practical NFC Peer-to-Peer Relay Attack Using Mobile Phones." RFIDSec 2010, LNCS 6370, Springer, pp. 35–49.
- [21] K. Krombholz, P. Frühwirth, P. Kieseberg, I. Kapsalis, M. Huber, E. Weippl. "QR Code Security: A Survey of Attacks and Challenges for Usable Security." HAS 2014 (HCI International), LNCS 8533, Springer, pp. 79–90.
- [22] Government of India. The Digital Personal Data Protection Act, 2023 (No. 22 of 2023). Gazette of India, 11 August 2023.
- [23] ISO/IEC 14443-1:2018 to 14443-4:2018. Cards and security devices for personal identification — Contactless proximity objects. International Organization for Standardization.

- [24] ISO/IEC 18092:2023. Information technology — Telecommunications and information exchange between systems — Near Field Communication Interface and Protocol (NFCIP-1).
- [25] ISO/IEC 18004:2024. Information technology — Automatic identification and data capture techniques — QR Code bar code symbology specification.
- [26] ISO/IEC 29100:2024. Information technology — Security techniques — Privacy framework.
- [27] A. Cavoukian. Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario, 2009 (rev. 2011).
- [28] W3C. Web Content Accessibility Guidelines (WCAG) 2.2. W3C Recommendation, 5 October 2023.
- [29] OWASP Foundation. Application Security Verification Standard (ASVS) 4.0.3, 2021; and OWASP Logging Cheat Sheet.
- [30] A. Shostack. Threat Modeling: Designing for Security. Wiley, 2014.
- [31] R. Anderson. Security Engineering: A Guide to Building Dependable Distributed Systems, 3rd ed. Wiley, 2020. (Ch. 13 "Physical Tamper Resistance", Ch. 16 "Physical Protection".)
- [32] R. Verdult. The (in)security of proprietary cryptography. PhD thesis, Radboud University Nijmegen / KU Leuven, 2015.
- [33] J. Bonneau, C. Herley, P. C. van Oorschot, F. Stajano. "The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes." IEEE Symposium on Security and Privacy 2012, pp. 553–567.
- [34] S. Garfinkel, H. R. Lipford. Usable Security: History, Themes, and Challenges. Morgan & Claypool, 2014.
- [35] Apple Inc. "Apple adds support for contactless student ID cards in Wallet." Apple Newsroom, 2 October 2018; and "Apple brings contactless student IDs on iPhone and Apple Watch to more universities," 13 August 2019.
- [36] C. Brocius. "My Arduino can beat up your hotel room lock." Black Hat USA 2012 (Onity HT lock vulnerability).
- [37] D. M'Raihi, S. Machani, M. Pei, J. Rydell. RFC 6238: TOTP: Time-Based One-Time Password Algorithm. IETF, May 2011.
- [38] S. Josefsson, I. Liusvaara. RFC 8032: Edwards-Curve Digital Signature Algorithm (EdDSA). IETF, January 2017.
- [39] E. Rescorla. RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3. IETF, August 2018.
- [40] M. Jones, J. Bradley, N. Sakimura. RFC 7519: JSON Web Token (JWT). IETF, May 2015.
- [41] NXP Semiconductors. MIFARE DESFire EV3 contactless multi-application IC (product data sheet, AES-128 mutual authentication); MIFARE Plus EV2 product data sheet. NXP, 2020–2022.
- [42] M. A. Sasse, S. Brostoff, D. Weirich. "Transforming the 'Weakest Link' — a Human/Computer Interaction Approach to Usable and Effective Security." BT Technology Journal 19(3), 2001, pp. 122–131.
- [43] IIIT-Delhi. Course Project Guidelines, CSE 347/652 | DES 306/525 Usable Security and Privacy, Monsoon 2026 (Dr. Arun Balaji Buduru). Course handout.

Note on source quality. Sources [8], [9] and [36] are security-conference or vendor disclosures rather than peer-reviewed papers; they are cited for the existence and nature of a publicly demonstrated attack, with the primary disclosure named and a reputable secondary report given. Vendor data sheets [41] are cited only for the cryptographic primitives a product family claims to implement, not for security assurance. Source [35] is cited only for the fact that named universities offer NFC student credentials in Apple Wallet, as stated by Apple; it is not cited as evidence of security properties.